

Appendix A

Answers to Multiple-Choice Questions

Chapter 1

- 1.** Answer: B. In the 1960s the military began using war games to test the effectiveness of their operational plans. These originally consisted of a red and blue team, where the red team would be the adversary.
- 2.** Answer: C. In 1983 a small software company named Hunter & Ready is credited with launching the first documented bug bounty program.
- 3.** Answer: C. While the chapter explicitly mentions penetration testing, red teaming, and bug bounties as the three core programs for an organization, vulnerability scanning is still an important piece of a well-rounded security program.
- 4.** Answer: B. The chapter highlights that bug bounty programs tap into the collective expertise of the security research community to identify vulnerabilities that might be missed by internal teams.
- 5.** Answer: A. Penetration testing and red teaming both involve identifying and exploiting vulnerabilities, but red teaming takes a more holistic approach by simulating the actions of a real-world adversary.
- 6.** Answer: B. The Control team in military-style red team exercises acts as the neutral third party, overseeing the exercise, providing guidance, and ensuring that it remains realistic and objective.
- 7.** Answer: A. Bug bounty programs are designed to incentivize security researchers to find and report vulnerabilities in a company's products

or services, helping to improve the overall security posture.

8. Answer: C. Responsible disclosure policies outline the process for researchers to report vulnerabilities to a company and ensure that they are disclosed in a way that does not cause harm or disruption.

9. Answer: D. AI and ML are increasingly being used in all aspects of cybersecurity, including penetration testing, red teaming, and bug bounties, to automate tasks, identify vulnerabilities, and generate realistic attack scenarios.

10. Answer: D. Continuous testing is essential for maintaining a strong security posture, because it allows organizations to identify and address vulnerabilities before they can be exploited and ensures that their security controls are up-to-date and effective.

Chapter 2

1. Answer: C. Red teaming promotes a creative and adversarial mindset, allowing participants to think like their opponents and challenge assumptions.

2. Answer: D. The MITRE ATT&CK Framework is a comprehensive knowledge base that systematically catalogs adversary tactics, techniques, and procedures (TTPs) observed across the kill chain.

3. Answer: C. Accurate emulation of adversaries allows red teams to identify risks within the organization and challenge assumptions.

4. Answer: B. Red teaming enhances resilience by identifying risks and weaknesses before they become actual problems.

5. Answer: A. An effective purple team requires experienced personnel from both teams, coordination, and time to conduct meaningful exercises; this may cause a burden on organizations.

6. Answer: B. The Bank of England's Cyber Assessment Framework (CBEST) is an intelligence-led approach to red teaming. It is a comprehensive framework used to assess and enhance the cyber resilience of UK financial institutions.

Chapter 3

1. Answer: D. CDN with Reverse Proxy using Rewrites is the most sophisticated option because it leverages a reverse proxy behind a CDN and additional filtering options to change URL on the fly.

2. Answer: A. AzureFrontDoor.Backend is the Azure service tag to set on the Azure firewall of the external redirector.

3. Answer: A. The purpose of a C2 channel is to send data, receive data, and maintain persistent access to an agent in order for an operator to interact with the victim's host.

4. Answer: B. The only correct way to start the SOCKS proxy for Mythic is to use **socks 8080**.

5. Answer: A. The external web server is the host that the CDN will be in front of to hide the domain of the web server.

6. Answer: B. The C2 IP and C2 domains are added to the /etc/hosts file to ensure the redirector can manually resolve the C2 domain after the A record pointing to the C2 is removed from the domain.

7. Answer: C. Mythic is the only open-source C2 for the options shown here; the remaining options are all only commercially available.

8. Answer: A. **Certbot** is an open-source tool used to create free SSL certificates through Let's Encrypt.

9. Answer: D. Mythic needs the fullchain.pem for the entire certificate chain (including the domain certificate and intermediate certificate) of the domain to establish SSL/TLS communications. The privkey.pem con-

tains the private key associated with your specific domain to perform decryption/encryption and digital signatures.

10. Answer: B. The jitter of your profile helps add randomness to each callback from your agent so that not every callback is happening at the exact same time and therefore avoids being predictable.

Chapter 4

1. Answer: A. The initial phase of a red team event should be planning to discuss the objectives and ROE.

2. Answer: B. Only one to two representatives from the organization should be in the communication channel because the more representatives included in the communication channel can jeopardize the engagement.

3. Answer: C. Certipy is an AD CS enumeration and abuse toolkit used for red team operations.

4. Answer: D. By default, the machine account quota in a domain is 10.

5. Answer: A. MFASweep is a tool to check MFA being enabled across multiple M365 endpoints that you can abuse. AskCreds is used to generate a pop-up on a compromised endpoint for credentials, and KnockKnock is a tool use to enumerate valid accounts.

6. Answer: B. Bright Data is the only correct option as a commercial provider that provides a service that rotates residential IPs for proxying traffic. CloudProxy is not a commercial tool, and ProxyTraffic is not a legitimate tool.

7. Answer: A. Reconnaissance is the phase of a red team implementation where you collect OSINT to prepare for the operation. This information gives you an overall view of the organization's attack surface.

8. Answer: D. Scheduling tasks, altering .LNK files, and using Registry run keys are all persistence techniques.

9. Answer: D. In the executive summary section of the report, the findings overview, scope overview, and overview of the assessment should all be included in the report.

10. Answer: B. When operating on a red team implementation, one user should be targeted per a request for Kerberoasting to avoid triggering alerts if many tickets are requested at once.

Chapter 5

1. Answer: B. Phone pretexting leverages the use of a phone to target an end user.

2. Answer: A. Magstripe technology was the first access control technology utilizing the magnetic stripes.

3. Answer: D. Low frequency operates over 125 kHz, and high frequency operates on 13.56 MHz.

4. Answer: C. The access control data we want will be associated to block 7, which contains the encrypted facility code and access card number. This is the block you'd decrypt with the master key.

5. Answer: A. The Quick Jim tool allows you to slide it behind the door's latch and pull on the deadlatch that is not properly in place and engaged.

6. Answer: C. The under the door tool can be utilized to go underneath a door; you pull down the handle on the other side of the door to open it.

7. Answer: B. TokenTacticsv2 integrated the ability to obtain an Azure Refresh Token from Evilginx's session cookies.

8. Answer: B. Explanation: Letter of authorization documents are your “get out of jail free” card showing you are authorized by the company that hired you to be performing the engagement.

9. Answer: A. Quick Jim can be used to pull a disengaged latch out of place when not installed properly.

10. Answer: B. Doppelgänger is the latest badge cloning firmware that is available open source.

Chapter 6

1. Answer: C. Post-exploitation activities focus on what attackers do after gaining initial access to a system. The goals include maintaining persistent access, escalating privileges to gain higher-level access, extracting valuable data, and evading detection to avoid being caught.

2. Answer: B. Red team engagements aim to mimic real-world attacks, particularly those from sophisticated adversaries like APTs, who prioritize maintaining long-term control, extracting sensitive data, and evading detection after initial access.

3. Answer: C. Creating scheduled tasks is a common persistence technique that allows attackers to ensure their malicious code is executed at regular intervals or system startup, thus maintaining access to the compromised system.

4. Answer: B. Web shells are scripts uploaded to a web server to execute arbitrary commands. This allows attackers to control the server remotely.

5. Answer: C. While PHP, ASP, and JavaScript are commonly used to create web shells, ADA is less commonly used for this purpose on web servers.

6. Answer: B. A reverse shell is a connection initiated from the target system to the attacker’s machine, allowing the attacker to gain control

over the target system, often bypassing network restrictions.

7. Answer: B. DNS tunneling is effective because DNS traffic is commonly allowed and not closely inspected by firewalls and monitoring systems, making it a stealthy method for transmitting data.

8. Answer: A. A bind shell sets up a listener on a specific port on the target machine, allowing the attacker to connect to it and execute commands.

9. Answer: C. Code obfuscation makes the code difficult to read and understand, helping to hide the presence and functionality of malicious backdoors from security analysts and detection tools.

10. Answer: D. User Mode, Kernel Mode, and Hypervisor Rootkits are types of rootkits. Network Mode Rootkit is not a recognized category.

11. Answer: C. Hardware and firmware backdoors inject code into the system firmware, allowing them to persist through OS reinstallation or hard drive replacement.

12. Answer: C. Custom daemons are services created by attackers to run with elevated privileges, ensuring persistent access to the compromised system.

13. Answer: B. The TDL3 rootkit modifies the master boot record (MBR) or volume boot record (VBR) to load its malicious components during the boot process, evading detection by user-space security tools.

14. Answer: B. Red team engagements simulate real-world attacks, helping blue teams understand advanced attack techniques and identify gaps in their defenses.

15. Answer: B. The C2 Matrix is a resource that documents and compares various C2 frameworks, helping security professionals choose the right tools for their needs.

16. Answer: A. HTTP/HTTPS tunneling disguises C2 traffic as regular web traffic, which is generally allowed and encrypted, making it a stealthy communication method.

17. Answer: B. Lateral movement involves moving across the network to avoid detection, gain further access, and exfiltrate sensitive data.

18. Answer: A. ProGuard is a popular tool for obfuscating Java applications, making the code harder to read and understand.

19. Answer: B. Living-off-the-land involves using existing system tools and legitimate software to perform malicious activities, reducing the need for additional malware and evading detection.

Chapter 7

1. Answer: C. Responder exploits NTLM/NetNTLM authentication, which is Microsoft's challenge-response authentication protocol. When a Windows system attempts to access network resources, it may fall back to NTLM authentication, especially in scenarios involving hostname resolution or accessing services by hostname. Responder works by poisoning responses to NetBIOS Name Service (NBT-NS), Link-Local Multicast Name Resolution (LLMNR), and Web Proxy Auto-Discovery (WPAD) protocol broadcasts, essentially pretending to be the resource that the client is trying to reach. This causes the client to attempt authentication with Responder, allowing it to capture the NTLM hashes.

2. Answer: B. Responder can be used for capturing authentication attempts and gathering network information, but it does not include built-in hash cracking functionality. Responder excels at capturing NetNTLMv1 and NetNTLMv2 hashes, gathering usernames from authentication attempts, setting up for NTLM relay attacks, and collecting network information through poisoned responses. The actual cracking of captured hashes must be done using separate tools like **hashcat** or John the Ripper. This incorrect option helps highlight the important distinction between hash capture (what Responder does) and hash cracking (what needs to be done afterward with different tools).

3. Answer: A. LDAP anonymous bind is a significant security concern that ethical hackers test for because it allows unauthenticated access to directory information. In misconfigured Active Directory environments, anonymous binds might be enabled, allowing attackers to query basic AD information without credentials, enumerate users and groups, gather organizational structure information and collect information for further attacks. This is why modern security practices recommend disabling anonymous binds and why later Windows versions disable it by default. However, it's still commonly found in legacy systems or misconfigured environments.

4. Answer: C. **WindapsSearch** with the **-secure** flag and paged results is the best option because it ensures LDAPS (LDAP over SSL/TLS) is used, encrypting the traffic and making it less suspicious to security monitoring tools.

5. Answer: C. Forests are completely isolated by default with no implicit trusts, which is a fundamental security principle in Active Directory design. This is important because each forest is a security boundary with its own schema, configuration, global catalog, and administrative boundaries. Trust relationships between forests must be explicitly configured. This isolation helps contain security breaches to a single forest. Even when trusts are established, they don't automatically grant administrative rights across forests.

6. Answer: B. BloodHound is best described as a graphical analysis tool because it uses graph theory to map out Active Directory environments. It visualizes relationships between users, computers, and groups, identifying complex attack paths that might be missed in manual analysis.

7. Answer: B. The statement about automatic remediation is false because SharpHound is strictly a data collection tool that gathers information about AD objects and relationships. It creates JSON files that BloodHound can ingest and performs enumeration of many AD attributes. It does not modify any settings or permissions.

8. Answer: B. GenericAll permissions on a Domain Admin account should be prioritized first because it represents an immediate, direct path to complete domain compromise. GenericAll permissions allow password resets without knowing the current password and modification of all account attributes.

9. Answer: B. SID History injection is the most concerning attack when testing forest trusts because SID History is designed to maintain access to resources when user accounts are migrated. In a forest trust scenario, SID History can be abused to inject SIDs from one forest into another and grant unauthorized access across forest boundaries. You can also potentially escalate privileges in the trusted forest. Golden Ticket attacks are typically confined to a single forest. NTLM relay attacks don't specifically exploit forest trust relationships. LDAP anonymous bind is a basic enumeration technique not specific to forest trusts.

10. Answer: B. Permanent role assignments for Global Administrator roles is the most critical risk because it defeats the core purpose of PIM's just-in-time access model. Permanent privileged access increases the attack surface continuously and makes credential theft more impactful, and it bypasses time-bound access controls.

11. Answer: D. Enrollment Service Certificate 1 (ESC1) vulnerability is the most severe because it allows complete domain compromise through the ability to obtain certificates for any domain user. This includes authentication as any user using the obtained certificate and persistence through long-lived certificate authentication. This can also be used to bypass MFA. The other options are less severe because ESC8 (NTLM relay) requires additional network access and specific conditions. Exportable private keys are dangerous only if the attacker already has access to the certificate. Client Authentication EKU alone is a legitimate configuration when properly secured.

12. Answer: C. Ret instructions are important for ROP chaining because they enable the attacker to chain multiple gadgets together sequentially and control program flow using the stack. It also can execute existing code pieces in a new order and build complex operations from simple

instructions. Each gadget ends with “ret” to pop the next gadget address. The stack is prepared with addresses of gadgets in sequence. When one gadget completes, “ret” loads the next gadget’s address. This creates a chain of legitimate code pieces that uses existing executable memory, and it bypasses NX by never introducing new code. It also maintains the execution flow control.

13. Answer: C. The **pop rax; ret -> 0x3b -> pop rdi; ret -> /bin/sh address -> syscall** sequence is correct because it follows the Linux x64 syscall calling convention properly. RAX must contain the syscall number (0x3b for execve), and RDI must contain the first argument (address of /bin/sh). Other registers can remain NULL in this case.

The chain works by setting RAX to 0x3b (execve syscall number) and setting RDI to point to the /bin/sh string, as well as executing the syscall instruction. In ROP chains, register values must be set before syscall, and the correct syscall numbers must be used. Arguments must be in correct registers, gadgets must exist in executable memory, and the chain must maintain stack alignment.

Chapter 8

1. Answer: B. To enhance the accuracy and relevance of AI-generated responses. RAG in cybersecurity combines the power of large language models with the ability to retrieve relevant, up-to-date information from external knowledge bases. This capability enhances the accuracy and relevance of AI-generated responses by grounding them in current, factual data.

2. Answer: D. Intrusion detection system (IDS). While an intrusion detection system is an important cybersecurity tool, it is not a core component of a RAG system. The typical components of a RAG system include an AI model for generating responses, a knowledge base containing up-to-date cybersecurity information, and embeddings.

3. Answer: B. By cross-referencing generated responses with retrieved factual information. RAG helps mitigate AI hallucinations by grounding

the language model's responses in factual, retrieved information. When generating responses to queries, the system retrieves relevant, up-to-date information from its knowledge base and uses this information to inform and validate the AI-generated content. This process helps ensure that the responses are based on accurate, current information rather than potentially incorrect or outdated knowledge embedded in the model's training data.

4. Answer: C. An attack that manipulates AI system inputs to produce unintended outputs. Prompt injection is a type of attack targeting AI systems, particularly large language models. It involves crafting input prompts in a way that manipulates the AI into producing unintended or potentially harmful outputs. This can be used to bypass security measures, extract sensitive information, or make the AI behave in ways that violate its intended use or ethical guidelines.

5. Answer: B. Bypassing content filters or security measures. One of the primary goals of prompt injection attacks is to bypass content filters or security measures implemented in AI systems. Attackers might craft prompts that trick the AI into ignoring its built-in restrictions, potentially leading to the generation of harmful, biased, or otherwise prohibited content. This can compromise the integrity and safety of AI-powered applications.

6. Answer: B. Bypassing an AI system's ethical constraints or content filters. In the context of prompt injection, *jailbreaking* typically refers to the process of crafting prompts that bypass or disable an AI system's built-in ethical constraints, content filters, or security measures. This allows users to make the AI generate content or perform actions that would normally be restricted or prohibited. Jailbreaking can be particularly concerning from a cybersecurity perspective because it may lead to the AI system being used for malicious purposes or in ways that violate privacy and security policies.

7. Answer: B. Language models (LLMs and SLMs). Large language models (LLMs) and small language models (SLMs) are currently the most vulnerable to prompt injection attacks. The reason is that they are de-

signed to understand and generate human-like text based on input prompts, making them susceptible to carefully crafted malicious inputs. Their flexibility and ability to handle a wide range of tasks also mean that attackers have more opportunities to find and exploit vulnerabilities in how the models interpret and respond to prompts.

8. Answer: C. Optimizing model training efficiency. Optimizing model training efficiency is important for AI development, but it's not a primary focus of AI red teaming. Red teaming typically concentrates on security and ethical concerns such as adversarial attacks, model bias, fairness issues, and vulnerabilities like prompt injection.

9. Answer: B. An attack to extract training data from the model. A model inversion attack is a type of privacy attack where an adversary attempts to reconstruct or infer information about the training data used to create the AI model. This can potentially lead to the exposure of sensitive or private information that was part of the training dataset. AI red teams often test for vulnerabilities to such attacks to ensure the privacy and security of the training data.

10. Answer: C. To protect individual privacy in the training data. Differential privacy is a mathematical framework used to protect individual privacy in datasets and AI models. In the context of AI, it's used to add carefully calibrated noise to the training process or model outputs. This makes it difficult to infer whether a particular individual's data was used in training, while still allowing the model to learn useful patterns from the data. AI red teams often evaluate the effectiveness of differential privacy implementations to ensure they provide adequate protection against privacy attacks.

11. Answer: C. Reconstructing a model's functionality through queries. Model stealing, also known as model extraction, is an attack where an adversary attempts to re-create, or "steal," the functionality of a target AI model by making numerous queries to it and analyzing the responses. The goal is to create a substitute model that closely mimics the behavior of the original, potentially allowing the attacker to bypass usage restrictions, avoid paying for API access, or gain insights into the

model's inner workings. AI red teams often attempt model stealing attacks to assess how well a system protects its intellectual property and maintains its competitive advantage.

12. Answer: B. To orchestrate operations for language model applications. LangChain is an open-source framework designed to simplify the development of applications using LLMs. These chains can include tasks such as retrieving information, processing text, and generating responses, making it easier to create powerful AI-driven applications.

13. Answer: D. Convolutional neural networks. While LangChain works with language models that use AI models, convolutional neural networks themselves are not a core component of LangChain. The framework focuses on higher-level abstractions like prompt chains, interaction with vector databases, and agents (for more complex, reasoning-based tasks). LangChain is designed to work with existing language models rather than implementing its own neural networks.

14. Answer: B. Creating multi-agent systems and workflows. LangGraph is an extension of LangChain that focuses on creating multi-agent systems and complex workflows. It provides tools and abstractions for designing and implementing systems where multiple AI agents can interact, collaborate, and execute multi-step processes.

15. Answer: B. An autonomous component that can perceive and act in an environment. An agent refers to an autonomous component within an AI-driven system. These agents are designed to perceive their environment (which could be data, other agents' outputs, or system states), make decisions, and take actions based on their programming and the current context. Agents can interact with each other and with external resources, allowing for the creation of complex, adaptive AI systems that can handle multi-step tasks or collaborative problem-solving.

Chapter 9

1. Answer: A. The main goal of attack surface management is to proactively identify and address vulnerabilities before they can be exploited,

thereby minimizing the potential attack vectors.

2. Answer: B. Attack surface management is usually conducted by internal security teams, possibly with the assistance of external consultants, to ensure comprehensive coverage of the organization's digital assets.

3. Answer: B. Bug bounty programs often incentivize participants by offering monetary or other material rewards based on the severity of the reported vulnerabilities, whereas VDPs generally do not have monetary incentives.

4. Answer: C. Bug bounty programs usually have defined rules and targets to guide participants on the scope and objectives of the program, making it more focused in comparison to VDPs, which might have a broader scope.

5. Answer: B. VDPs establish a formalized process where individuals can report identified vulnerabilities to the organization, facilitating responsible disclosure and timely mitigation.

6. Answer: B. VDPs often provide legal protection to individuals who report vulnerabilities, shielding them from legal actions as long as they adhere to the guidelines outlined in the program.

7. Answer: B. Bug bounty programs primarily involve a community of ethical hackers and security researchers from the external community, leveraging their expertise to identify vulnerabilities.

8. Answer: C. Attack surface management adopts an ongoing approach, with regular assessments and frequent adjustments based on emerging threats and organizational changes, ensuring a resilient defense against evolving cyber threats.

9. Answer: C. Attack surface management embodies a proactive approach as it seeks to identify and mitigate vulnerabilities before they can be exploited, actively minimizing the organization's exposure to threats.

10. Answer: B. In bug bounty programs, the scope refers to the defined range or domain within which participants are allowed to find and report vulnerabilities, guiding them on the targets and boundaries of the program.

11. Answer: C. Gobuster is a tool used to brute-force URIs (directories and files) in websites.

12. Answer: B. FFuf is a very fast web fuzzer used for file and directory enumeration.

13. Answer: B. Certificate transparency helps in detecting fraudulently issued SSL certificates, thereby improving the security of SSL/TLS certificates. However, it can also be very effective for reconnaissance.

14. Answer: B. Amass is an advanced open-source tool used to help information security professionals perform network mapping of attack surfaces and external asset discovery using open-source information-gathering and active reconnaissance techniques.

15. Answer: B. Maltego is used for OSINT.

Chapter 10

1. Answer: B. The OWASP Top 10 for LLM Applications focuses on vulnerabilities specific to language models, such as prompt injection and insecure output handling.

2. Answer: B. Burp Suite is a comprehensive tool for web application security testing, essential for a web application testing lab.

3. Answer: B. Isolating the lab environment ensures that vulnerabilities tested in the lab do not impact live production systems.

4. Answer: B. Business logic flaws are issues in the application's functionality that attackers can exploit to perform unintended actions.

5. Answer: B. **SELECT * FROM users WHERE id = ' OR '1'='1';** is a classic SQL injection payload that manipulates the SQL query to return all records.

6. Answer: C. Brute-force attacks involve systematically guessing passwords until the correct one is found, exploiting weak or common passwords.

7. Answer: D. Broken access control occurs when restrictions on what authenticated users can do are not properly enforced, allowing them to access unauthorized functions or data.

8. Answer: D. Stored (or persistent) XSS involves injecting scripts that are stored on the server and executed when users access the data.

9. Answer: B. The X-CSRF-Token header is used to include a CSRF token in requests, which helps validate the legitimacy of requests.

10. Answer: B. SSRF vulnerabilities allow attackers to make requests to internal resources that should not be accessible from the outside.

11. Answer: C. The X-Frame-Options header prevents the web page from being embedded in an iframe, which helps mitigate clickjacking.

12. Answer: C. LFI vulnerabilities allow attackers to include files from the local server, potentially exposing sensitive information.

13. Answer: D. Building SQL queries using string concatenation with user input can lead to SQL injection.

14. Answer: C. A CSRF token is used to validate that a request is legitimate and not forged by an attacker, thus preventing CSRF attacks.

15. Answer: B. The server fetches the contents of the internal admin page and displays it to the attacker. In an SSRF attack, the attacker manipulates the input to make the server send a request to an unintended location, such as an internal service or a sensitive endpoint. In this scenario, the attacker provides a URL that points to an internal admin page

(<http://127.0.0.1:8080/admin>). The server's code, which does not validate or sanitize the input URL, fetches the content of the internal admin page and returns it to the attacker. This approach can reveal sensitive information and potentially allow further exploitation. While SSRF can sometimes be used for port scanning, the given example demonstrates fetching content from an internal page, not scanning ports.

Chapter 11

1. Answer: D. Patch management. The framework for external attack surface discovery and exploitation, as described in the text, includes discovering assets, monitoring changes, getting actionable insights, and amplifying security testing. Patch management is not mentioned as one of the core concepts in this framework.

2. Answer: B. To communicate the characteristics and severity of software vulnerabilities. CVSS is an open framework for communicating the characteristics and severity of software vulnerabilities. It provides a way to capture the principal technical characteristics of a vulnerability and produce a numerical score reflecting its severity.

3. Answer: A. Exploit Prediction Scoring System. EPSS is a data-driven effort for estimating the probability that a software vulnerability will be exploited in the wild.

4. Answer: C. CISA. The Known Exploited Vulnerabilities (KEV) Catalog is maintained by the Cybersecurity and Infrastructure Security Agency (CISA).

5. Answer: C. To identify and mitigate security vulnerabilities across various platforms. The ProjectDiscovery Nuclei Scanner is a fast and extensible open-source vulnerability scanner designed to identify and mitigate security vulnerabilities across modern applications, infrastructure, cloud platforms, and networks.

6. Answer: C. YAML. Nuclei uses a template-driven approach, where each template is a YAML file that defines the steps needed to detect spe-

cific vulnerabilities. It also supports JSON format.

7. Answer: B. Low-rank adaptation. LoRA is a machine learning technique designed to efficiently fine-tune language models by introducing trainable low-rank matrices into each layer of a pretrained model while keeping the original weights frozen.

8. Answer: B. Retrieval-augmented generation. RAG combines the capabilities of language models with data retrieval from vector databases and other sources, providing contextually relevant information that enhances the model inference.

9. Answer: C. Limited ability to generate potentially malicious payloads for testing. AI models with strong guardrails may refuse to create or assist in crafting potentially malicious payloads, even when these are essential for security testing. This can limit the ability of bug bounty hunters to effectively test for certain types of vulnerabilities.

10. Answer: C. Generation of factually incorrect or made-up information. Hallucinations or confabulations in AI refer to instances where the AI model generates information that is factually incorrect, made up, or not grounded in reality. This can lead to serious challenges in bug bounty hunting, where accuracy is critical.

11. Answer: D. Exploitation. The CVSS consists of four metric groups: Base, Threat, Environmental, and Supplemental. Exploitation is not mentioned as one of the metric groups in the CVSS.

12. Answer: A. It allows for fine-tuning of larger models on limited hardware. QLoRA builds on LoRA by incorporating 4-bit quantization, which further reduces memory usage and enables the fine-tuning of extremely large models on hardware with limited resources.

13. Answer: B. To enable the AI to perform tasks using external tools. Tool calling allows AI agents to link to external tools, enabling them to perform tasks more effectively by utilizing specialized software or services.

14. Answer: B. To reduce memory constraints. In the fine-tuning parameters discussed, gradient accumulation steps are set to 8, meaning gradients will accumulate over 8 batches before updating the model weights. This helps manage memory constraints during the training process.